

FOR_03 — Cyber Crime, Incident Response, Imaging & the Web/Email Forensics Block

Covers TP-II Unit 1 (Cyber Crime → search & seizure → imaging & hashing → recovery) and Unit 2 (Web Browsers, Email, VM & Cloud forensics)

This is the **operational heart** of the Computer Forensic elective. TP-I taught you what forensic science *is* and where data *hides*; this file is about what you actually *do* when a crime has happened: classify it, respond first, seize correctly, image without altering, hash to prove integrity, and then recover and interpret. Two set-piece answers in this file are worth pre-writing until you can produce them cold: the **order of volatility** (§4) and the **line-by-line email-header trace** (§9). Both are near-certain descriptive questions.

Reading order: §1–§2 (cyber crime taxonomy) read once for breadth; §3–§6 (first responder → imaging → recovery) are the exam core, three passes; §7 (browsers) and §8–§9 (email) are pure artifact/procedure marks; §10 (VM/cloud) is a short high-value differentiator.

△ **Accuracy warning on Indian law.** Section numbers for the IT Act 2000, the BNS/BNSS/BSA 2023 and the DPDP Act 2023 are examinable and easy to get wrong. Every section number below that I am not certain of is flagged △ **verify**. In the exam, where the old and new codes both apply, **cite both** — e.g. "§65B Indian Evidence Act 1872, now §63 Bharatiya Sakshya Adhiniyam 2023" — and you cannot be marked wrong for citing a superseded number.

§1. Cyber Crime — Concept, Forms and Classification

1.1 Concept — the intuition first

Ordinary crime needs the criminal and the victim to share time and place. **Cyber crime removes both constraints.** An attacker in one country can, at 3 a.m. their time, defraud a victim asleep on another continent, using an intermediary machine in a third country, and leave the only witness — a log file — on a server in a fourth. Three properties follow, and they shape everything the forensic examiner does:

1. **Volatility and remoteness.** The evidence is bits, not objects. It is trivially altered, easily deleted, distributed across jurisdictions, and often held by a third party (an ISP, a cloud provider, a bank) rather than at the scene.
2. **Anonymity and attribution difficulty.** IPs are shared and spoofable, identities are borrowed, and Tor/VPN/proxies break the physical link between act and actor. **The central investigative problem in cybercrime is attribution** — proving *who* sat at the keyboard.
3. **Scale.** One script can attack a million machines. A single fraud kit can run thousands of phishing pages. The economics favour the attacker.

Definition (write one of these): Cyber crime is **any unlawful act where a computer, computer system, computer network or the data stored in it is either the *target* of the offence, the *tool* used to commit the offence, or *incidental* to the offence** (used to store or communicate material relating to it).

That definition already gives you the first classification.

1.2 Classification by the role of the computer

Class	The computer is...	Examples
Computer as target	The victim	Hacking/unauthorised access, denial of service (DoS/DDoS), website defacement, ransomware, data theft, virus/worm release
Computer as tool/instrument	The weapon	Online fraud, phishing, identity theft, forgery, cyber-stalking, child sexual abuse material (CSAM) distribution, IPR piracy
Computer as incidental	A store/record	A drug dealer's spreadsheet of clients; a murderer's search history; a fraudster's chat logs
Crimes associated with the prevalence of computers	The environment	Software piracy, copyright/trademark violation, counterfeit hardware

1.3 Classification by the victim / target of the harm

This is the classification Indian exam books usually want (it maps onto the way the IT Act and BNS group offences). Learn the four buckets with two or three examples each.

Against...	Offences	Illustrative Indian legal hook (△ verify each section)
Individual / person	Cyber-stalking, cyber-bullying, online harassment, defamation, identity theft, phishing, email spoofing, morphing, revenge porn, sextortion	IT Act §66C (identity theft), §66D (cheating by personation), §66E (violation of privacy); BNS provisions on stalking/defamation △ verify
Property	Online financial fraud, credit-card/UPI fraud, intellectual-property theft, software piracy, data theft, transmitting viruses, ransomware	IT Act §43 (damage to computer, civil), §66 (computer-related offences), §65 (tampering with source code)
Organisation / government (cyber-terrorism)	Hacking of government systems, attacks on critical infrastructure, cyber-espionage, cyber-terrorism, website defacement of official portals	IT Act §66F (cyber terrorism), §70 (protected systems), §70A/§70B (NCIIPC/CERT-In)
Society at large	CSAM, obscenity/pornography, online gambling, financial scams at scale, fake news, trafficking	IT Act §67 , §67A , §67B (obscene/sexual/child-sexual material)

Exam framing: for a 5-mark "classify cyber crime", give **both** the role-based (target/tool/incidental) and the victim-based (person/property/government/society) classifications — two tables, one page. For 10 marks add three worked examples and the relevant IT Act sections.

1.4 Internal vs External attacks — a guaranteed sub-question

Aspect	Internal (insider) attack	External (outsider) attack
Who	Employee, contractor, ex-employee, privileged user	Hacker, competitor, criminal group, state actor, script kiddie
Access	Already has legitimate access and knowledge of systems, controls and value of data	Must <i>gain</i> access — exploits, phishing, credential stuffing, brute force
Detection	Hard — activity looks authorised; blends with normal work	Comparatively easier — perimeter tools (firewall/IDS) log the intrusion
Motive	Grievance, greed, espionage, negligence	Financial gain, ideology, notoriety, espionage

Typical evidence	Access logs beyond role, off-hours activity, mass downloads/USB exfiltration, deleted logs, privilege misuse	Firewall/IDS logs, exploited service logs, malware artifacts, foreign IPs, new accounts/backdoors
Defence	Least-privilege, separation of duties, DLP, UEBA, logging & review, exit controls	Firewall, IDS/IPS, patching, MFA, segmentation

Key exam line: *most studies place a large share of serious breaches at the hands of insiders or insider-enabled access, and insiders are the harder problem because they defeat perimeter defences by design. State this and give the least-privilege / separation-of-duties countermeasure.*

1.5 Crimes related to social media

Crime	What happens	Investigative artifacts
Profile impersonation / fake accounts	Cloning someone's identity to defame or defraud their contacts	Account metadata, creation IP, device, phone/email used to register (subpoena the platform)
Cyber-stalking / harassment / trolling	Repeated targeted abuse, threats	Message logs, timestamps, account attribution
Cyber-bullying	Sustained abuse, often of minors	Same; note child-protection provisions
Sextortion / morphing / revenge porn	Coercion using real or fabricated intimate images	IT Act §66E/§67A; image EXIF, upload logs
Fake news / rumour / incitement	Coordinated disinformation, mob incitement	Forwarding chains, group metadata, first-originator (see the traceability debate on messaging apps)
Financial scams	Fake giveaways, romance scams, investment/"pig-butcher" fraud, job scams	Chat logs, payment trails (UPI/wallet), mule accounts
Account takeover	Credential theft, SIM-swap → account hijack	Login IP history, session tokens, recovery-email changes

How social-media evidence is obtained: (1) **open-source collection** of public posts with proper documentation (screenshots with URL, timestamp, hash of the capture, and ideally page source / web-archive capture); (2) **legal process to the platform** for subscriber and content data — in India via the platform's law-enforcement portal, MLAT for foreign providers, or orders under the IT Act / BNSS; (3) **device forensics** of the suspect's phone recovering the app's local databases. Under the **IT Rules 2021**, significant social-media intermediaries have compliance and (for messaging) first-originator obligations ⚠ verify current status/litigation before quoting.

1.6 ATM and banking frauds — memorise the mechanisms

This is a favourite because it mixes technique, law and everyday relevance. Learn each *mechanism* and its *counter-artifact*.

Fraud	Mechanism	Detection / evidence
Card skimming	A hidden reader placed over the ATM/POS card slot copies the magnetic stripe (Track 1/Track 2) data ; a pinhole camera or overlay keypad captures the PIN	Physical skimmer recovery; ATM CCTV; transaction-location anomalies; cloned-card use pattern

Card cloning	Skimmed stripe data is written to a blank card; used where magstripe fallback is allowed. EMV chip cards resist cloning because the chip generates a per-transaction cryptogram that cannot be copied	Duplicate transactions in two places; magstripe-fallback flag in logs
Card trapping / Lebanese loop	A device traps the physical card in the slot; the fraudster retrieves it after the victim leaves	Physical device; CCTV
Shimming	A thin device inside the chip reader intercepts chip data (harder to monetise than skimming)	Slot inspection; anomaly logs
Phishing	Fake bank email/SMS/website harvests card number, CVV, net-banking credentials, OTP	Look-alike domain, email headers (§9), hosting/registrar records, victim's browser history
Vishing	Voice phishing — caller poses as bank/RBI/KYC and extracts OTP/CVV/PIN over the phone	Call records (CDR — see FOR_04), spoofed caller ID, mule-account trail
Smishing	SMS phishing with a malicious link or fake helpline number	Sender ID/header, URL analysis
SIM swap	Fraudster obtains a duplicate SIM of the victim's number → intercepts OTPs → drains accounts	Telco SIM-change logs, IMSI change, transaction timing vs SIM issuance
UPI frauds	(a) Collect-request trick — victim tricked into <i>approving</i> a "receive money" request that actually <i>debits</i> ; (b) fake UPI apps/handles; (c) QR-code scam — scanning a QR <i>pays</i> , it never <i>receives</i> ; (d) screen-mirroring/remote-access apps (AnyDesk/TeamViewer) stealing the UPI PIN; (e) fake customer-care numbers	UPI transaction reference (UTR/RRN), VPA/handle, PSP logs, device ID, beneficiary (mule) account KYC
Man-in-the-middle / net-banking trojans	Malware injects fake fields or redirects transfers	Malware analysis, browser injection artifacts
Money mules	Layer of recruited accounts that receive and forward stolen funds to obscure the trail	Account-to-account graph analysis, KYC of mules

The single most quotable prevention fact: the **OTP/PIN/CVV are never shared** — every OTP SMS in India carries that warning because social-engineering (phishing/vishing) — not technical hacking — is how the overwhelming majority of retail banking fraud actually succeeds. Report financial cyber-fraud immediately to the **1930 helpline / cybercrime.gov.in** (I4C) to trigger the "golden hour" transaction-freeze workflow.

1.7 Data privacy issues

Concept: privacy harm arises whenever personal data is collected, processed, shared or leaked beyond what the individual expected or consented to. The forensic examiner meets this in two ways: as a *type of offence* (data breach, unauthorised disclosure, surveillance) and as a *constraint on the investigation itself* (you may not trawl personal data beyond the scope of the warrant).

Issue	Explanation
Data breach / leakage	Unauthorised access to and exfiltration of personal or financial data

Unauthorised profiling / tracking	Aggregation across sources to build a profile without consent
Function creep	Data collected for one purpose reused for another
Surveillance	State/private monitoring without lawful basis
Consent & purpose limitation	Data should be collected only with informed consent and used only for the stated purpose
Data minimisation & retention	Collect only what is needed; delete when no longer needed
Cross-border transfer	Data leaving the jurisdiction escapes local law

Indian legal framework (△ **verify sections before quoting**):

- **IT Act 2000 §43A** — compensation for a body corporate's failure to protect **sensitive personal data** (and the **SPDI Rules 2011**).

- **IT Act §72 / §72A** — breach of confidentiality and privacy; disclosure in breach of a lawful contract.

- **IT Act §66E** — violation of privacy (capturing/transmitting images of a private area).

- **Digital Personal Data Protection Act, 2023 (DPDP Act)** — India's dedicated data-protection statute: introduces **Data Principal / Data Fiduciary / Data Processor**, consent, purpose limitation, the **Data Protection Board of India**, and penalties. △ Rules were still being finalised/rolled out — verify the operative status and any section numbers before writing them as fact. Awareness level is enough for the exam; do **not** invent section numbers.

- **Constitutional basis**: *K.S. Puttaswamy v. Union of India (2017)* held **privacy to be a fundamental right** under Article 21 △ verify citation spelling before quoting.

§2. Attacks on the Wire and the Web

2.1 Packet sniffing

Concept — intuition first. A network delivers data in **packets**. A **sniffer** (packet analyser) is software (or hardware) that puts a network interface into **promiscuous mode** (wired) or **monitor mode** (Wi-Fi) so it captures **every** frame it can see, not just those addressed to it, and reassembles them into readable traffic.

- On an old **hub**, every port sees every frame → sniffing is trivial.
- On a **switch**, a host normally sees only its own traffic → the attacker must first **defeat the switch**: **ARP spoofing/poisoning** (redirect traffic through the attacker), **MAC flooding** (overflow the CAM table so the switch fails open and broadcasts), or **port mirroring/SPAN** (the legitimate/administrative way).

Use	Legitimate	Malicious
Purpose	Network troubleshooting, IDS, lawful interception, forensic capture	Stealing credentials, session tokens, PII from unencrypted traffic
Tools	Wireshark , tcpdump, tshark, Zeek	Same tools, plus attack frameworks

Forensic relevance: the examiner *uses* sniffing to capture evidence (a **PCAP** file is the network equivalent of a disk image) and *investigates* sniffing as an attack. **Defence**: end-to-end encryption (TLS/HTTPS, SSH, VPN) makes captured payloads useless; switched networks, port security, and dynamic ARP inspection raise the bar.

Exam line: encryption defeats the *confidentiality* attack of sniffing but not the *metadata*

— an eavesdropper still sees who talked to whom, when, and how much (traffic analysis).

2.2 Spoofing — the family (very examinable; learn the table cold)

Spoofing = forging an identity field so traffic or a message appears to come from someone else.

Type	What is forged	How it is abused	Detection / defence
IP spoofing	Source IP address in the packet header	DoS/DDoS reflection & amplification, bypassing IP-based trust, hiding origin	Ingress/egress filtering (BCP 38), reverse-path checks; hard to get replies back (blind)
MAC spoofing	Source MAC address of the NIC	Bypass MAC filtering, impersonate a device, evade tracking	Port security, DHCP snooping, 802.1X
ARP spoofing / poisoning	The IP↔MAC mapping in victims' ARP caches	Man-in-the-middle on a LAN, session hijacking, sniffing on a switch	Static ARP, Dynamic ARP Inspection , arpwatch
DNS spoofing / cache poisoning	The name→IP answer	Redirect victims to a fake site (pharming), MITM	DNSSEC , randomised source ports/query IDs, encrypted DNS
Email spoofing	The From: / envelope sender of an email	Phishing, BEC (business email compromise), malware delivery	SPF, DKIM, DMARC (see §9)
Caller-ID / SMS-sender spoofing	The displayed phone number / sender ID	Vishing/smishing, impersonating banks	Telco-side controls; user education
Website / URL spoofing (typosquatting/homograph)	The apparent domain (look-alike, Unicode homographs)	Phishing, credential theft	Certificate inspection, brand monitoring, punycode display
GPS spoofing	The location signal	Defeat geofencing, mislead navigation	Multi-constellation checks, signal-strength anomaly detection

MCQ trap: *ARP spoofing works at Layer 2 within a broadcast domain; DNS spoofing operates on name resolution; IP spoofing forges the L3 source address.* Options routinely swap these.

Pharming = DNS-level redirection to a fake site; phishing = luring the user to click.

2.3 Web security — the OWASP-flavoured core

SQL injection is also covered in the DBMS/SQL CORE material (see the SQL-injection section of the shared DBMS notes); here take the **forensic slant** — how each attack *appears in the evidence*.

(a) SQL Injection (SQLi)

- **Concept:** unsanitised user input is concatenated into a SQL query, so attacker input becomes **executable SQL**. Classic: `' OR '1'='1` in a login bypasses authentication; `UNION SELECT` exfiltrates other tables; **blind/time-based** SQLi infers data from response behaviour.
- **Forensic footprint:** web-server access logs show tell-tale payloads (`%27, UNION, OR 1=1, --, information_schema`), spikes in 500 errors, and unusual query strings; the DB error log and slow-query log may confirm. **Defence:** parameterised queries/prepared statements, input validation, least-privilege DB accounts, WAF. **Legal hook:** IT Act §66 / §43 △ verify.

(b) Cross-Site Scripting (XSS)

- **Concept:** attacker injects **client-side script** that runs in another user's browser in the context of the trusted site. **Stored** (persisted on the server, e.g. a comment), **Reflected** (bounced back from a request/link), **DOM-based** (client-side sink). Steals cookies/session tokens, keylogs, defaces.
- **Forensic footprint:** `<script>/onerror=/javascript:` in stored content or request logs; outbound requests to attacker collectors. **Defence:** output encoding, Content-Security-Policy, `HttpOnly` cookies, input validation.

(c) Cross-Site Request Forgery (CSRF)

- **Concept:** a victim who is *already logged in* to a site is tricked into submitting an unintended state-changing request (e.g. a hidden form that transfers money) because the browser auto-attaches their session cookie. **The site cannot tell the request was not intended.**
- **Forensic footprint:** a valid, authenticated request with a **foreign Referer/Origin** and no user intent; correlate with the victim visiting a malicious page. **Defence:** anti-CSRF tokens, `SameSite` cookies, re-authentication for sensitive actions.
- **XSS vs CSRF (classic compare):** XSS **abuses the site's trust in the user's browser** (runs script); CSRF **abuses the site's trust in the authenticated user** (rides their session). XSS can defeat CSRF tokens; CSRF cannot do what XSS does.

(d) Session hijacking

- **Concept:** stealing or forging a valid **session identifier** (cookie/token) to impersonate the user. Vectors: **sniffing** an unencrypted session, **XSS** stealing the cookie, **session fixation** (forcing a known ID), predictable IDs, **MITM**.
- **Forensic footprint:** the same session ID used from **two IPs/geographies/user-agents** simultaneously; impossible-travel logins. **Defence:** TLS everywhere, `HttpOnly+Secure+SameSite` cookies, rotate ID on login, bind session to fingerprint, short timeouts.

(e) Others to name in a list

Directory traversal (`../../../../etc/passwd`), file-upload abuse (web-shell), command injection, SSRF, insecure deserialisation, broken access control (IDOR), clickjacking, brute-force/credential stuffing, DoS/DDoS.

2.4 Malware taxonomy — the whole family in one table

Malware	Defining property	Spreads by	Forensic artifacts
Virus	Attaches to a host file/program ; needs the host to be run	User executing infected files	Modified executables, changed hashes, infected file dates
Worm	Self-replicating ; spreads without a host and without user action across networks	Network exploits, shares, email	Sudden network scanning, new listening ports, mass connections
Trojan horse	Disguised as legitimate software; does not self-replicate	User is tricked into running it	Suspicious binary, persistence keys, C2 traffic
Ransomware	Encrypts files (or locks the system) and demands payment	Phishing, RDP, exploit kits	Mass file rename/encryption, ransom notes, deleted shadow copies, encryption-tool artifacts

Rootkit	Hides its presence by subverting the OS (user-mode or kernel-mode); can hide from the live OS itself	Bundled with other malware	Discrepancies between live view and offline image; hooked APIs; why dead-box imaging matters
Bootkit	Rootkit in the MBR/VBR/UEFI — loads before the OS	Boot-chain infection	MBR/ESP anomalies (see FOR_02 §3)
Keylogger	Records keystrokes (software or hardware)	Trojan, physical device	Log file, hardware device on keyboard cable, hooking
Spyware / Adware	Covert monitoring / unwanted ads and tracking	Bundled installers	Browser hijack, tracking cookies, exfil traffic
Botnet (bot/zombie)	Compromised host under remote C2 ; used en masse for DDoS/spam/mining	Worm/trojan	Beaconing to C2, IRC/HTTP/DNS command traffic
Logic bomb	Dormant code that fires on a condition/date	Insider, trojan	Conditional trigger in code; ties to insider threat
Backdoor / RAT	Covert remote access channel	Trojan, exploit	Listening service, new account, remote-access tool
Fileless malware	Lives in memory / living-off-the-land (PowerShell, WMI), little on disk	Script, macro	Memory-only artifacts → volatile capture essential (Volatility)
Cryptominer	Steals CPU/GPU to mine cryptocurrency	Trojan, drive-by	High resource use, mining-pool traffic
APT	<i>Advanced Persistent Threat</i> — a well-resourced actor, long dwell time, stealthy	Targeted, multi-stage	Low-and-slow persistence, custom tooling, lateral movement

The three canonical distinctions for MCQs:

1. **Virus needs a host and user action; worm is self-replicating and self-propagating; trojan does not self-replicate at all.** These three are swapped in every question set.
2. **Rootkit = hiding**, not damage per se. Its existence is the strongest textbook argument for **dead-box (offline) imaging** and **memory forensics** — a compromised live OS cannot be trusted to report its own state.
3. **Fileless / APT** → the disk may be nearly clean; **RAM is the crime scene** → capture volatile memory first (order of volatility, §4).

§2.5 Likely exam questions (Units on cyber crime & attacks)

Marks	Question
5	Classify cyber crimes with examples.
5	Distinguish between a virus, a worm and a trojan horse.
5	What is packet sniffing? How is it done on a switched network?
5	Distinguish between phishing, vishing and smishing.
5	Distinguish internal and external attacks.
10	Explain the different types of spoofing with examples and their defences.
10	Describe the common ATM and UPI frauds and how each is investigated.
10	Explain SQL injection, XSS and CSRF, and how each appears in web-server evidence.

15	"Attribution is the central problem of cyber-crime investigation." Discuss with reference to spoofing, anonymisation and the classification of cyber crimes.
15	Discuss malware taxonomy and explain why rootkits and fileless malware change the forensic acquisition strategy.

MCQ traps

- **Worm self-replicates without user action; virus needs a host + execution.**
- **ARP spoofing = L2 MITM; DNS spoofing/poisoning = fake name resolution (pharming).**
- **Promiscuous mode** (wired) / **monitor mode** (Wi-Fi) enables sniffing.
- **EMV chip resists cloning; magstripe fallback is the weakness.**
- **CSRF rides the authenticated session; XSS runs injected script.**
- Scanning-a-QR-code **pays**, it does not receive money (UPI collect/QR scam).

§3. The First Responder and Incident Response

3.1 Concept

The **first responder** is the first trained person to reach a **digital crime scene**. Their job is **not** to solve the case; it is to **not destroy it**. Everything valuable about digital evidence — its integrity, its admissibility, the RAM that is about to vanish — is decided in the first few minutes, usually by someone who is *not* the eventual lab examiner. Hence the first responder needs a rehearsed drill, not improvisation.

Guiding doctrine (ACPO — see FOR_04 §2): **do not change the data; if you must, be competent and document why**; keep a full record; the officer in charge is responsible for compliance.

3.2 First responder — role and duties

1. **Secure and isolate the scene** — keep people away from keyboards and power; treat it like any crime scene (photograph, log entries/exits, don't let anyone "just save their work").
2. **Assess power state** — is the machine **on, off, or sleeping**? This single fact drives every subsequent decision (§3.4).
3. **Do not touch the keyboard/mouse** except as a deliberate, documented capture step.
4. **Photograph everything** — screen (as displayed), cable layout, serial numbers, connected devices, the room, and any notes/passwords stuck nearby.
5. **Identify and preserve volatile evidence** if trained and authorised (RAM, running processes, network connections) **before** power decisions.
6. **Identify all storage and networked devices** — don't miss the NAS in the cupboard, the phone charging on the desk, the cloud that this machine is logged into.
7. **Prevent remote wiping** — isolate from the network (pull the network cable / Faraday bag for phones) so nobody can trigger a remote wipe or alter data.
8. **Establish and begin the chain of custody** (see FOR_01 §4.5) — label, seal, log.
9. **Do not run programs on the suspect machine** or open files "to check" — every action changes the evidence.
10. **Hand over** to the examiner with complete notes.

3.3 First responder toolkit

Category	Items
Documentation	Notebook/forms, chain-of-custody forms, evidence labels, camera , marker pens
Anti-static & packaging	Anti-static bags, Faraday bags/boxes (for phones/radios), evidence tape, boxes, cable ties
Acquisition hardware	Hardware write blockers (SATA/IDE/USB/NVMe), forensic imaging device/duplicator , sterile (wiped, verified) target drives, adapters and connectors
Live/volatile capture	Trusted incident-response USB with statically-linked tools (memory-capture, process/network listing), a clean external drive to receive the dump
Software	Bootable forensic OS/live CD (e.g. a Linux forensic distro), imaging tools (dd/dcfldd, FTK Imager), hashing tools
Miscellaneous	Torch, screwdriver/tool kit, gloves, tamper-evident seals, spare storage, power strip, UPS/portable power to keep a live machine alive during capture

3.4 Pull-the-plug vs graceful shutdown — reasoning (a set-piece)

The examiner must choose how to power down. There is no universal rule; you **reason from the OS, the file system, the risk of destructive logic, and the value of volatile data**. Show the reasoning in the exam — that is what earns the marks.

Option	What it is	Pros	Cons / risks
Pull the plug (yank power at the wall; for laptops remove battery too)	Instant, uncontrolled power loss	Freezes the disk state — no shutdown scripts, no logoff wiping, defeats anti-forensic "clean shutdown" wipers and some ransomware timers ; prevents changes	Destroys all volatile data (RAM, network state) ; risk of file-system corruption / open-file loss; risk on some databases/journaling edge cases
Graceful shutdown	Normal OS shutdown	Clean file system, no corruption	Runs shutdown scripts that may delete temp files, clear the pagefile (ClearPageFileAtShutdown), flush/rotate logs, or trigger wiper/logic bombs ; changes many timestamps; still destroys RAM
Live acquisition first, then power decision	Capture RAM (and if needed a live disk image / triage), <i>then</i> pull the plug	Preserves the most volatile evidence; best of both	Requires trained responder + trusted tools; interacting with the live system changes some state (documented, justified per ACPO Principle 2)

Decision guide (state this logic):

- **If the machine is OFF** → **leave it off**. Do **not** boot it; image the disk with a write blocker (dead-box). Booting alters hundreds of files (FOR_02 §3).
- **If the machine is ON** and RAM/volatile data matters (encryption keys, running malware, open network sessions, cloud sessions, fileless malware) → **capture volatile memory first**, document the live state, isolate from the network, **then** decide on power-down.
- **Choice of power-down when on**: for a **workstation/Windows desktop** where you fear anti-forensic scripts on shutdown, **pull the plug** after volatile capture. For a **server / database / RAID / anything where uncontrolled loss risks massive corruption or where destroying in-flight transactions is worse**, a **controlled shutdown or live imaging** may be preferred.

- **Encrypted disks (BitLocker/FileVault/VeraCrypt):** if the volume is **currently unlocked**, pulling power re-locks it and you may **lose access forever** unless you have the key → capture the key from RAM / do a **live logical acquisition** *before* power-down. This is the strongest modern argument against a reflexive pull-the-plug.
- **Sleeping/hibernating machine:** treat as ON; hiberfil.sys on disk may already hold a RAM image.

One-line exam answer: "Off → keep off and image dead-box. On → capture volatile memory first (especially if the disk is encrypted and currently unlocked), then choose pull-the-plug for a workstation at risk of shutdown-wipers, or a controlled/live acquisition for a server or an unlocked encrypted volume." Memorise that sentence.

§4. Search & Seizure and the Order of Volatility

4.1 Legal authority (India) — ⚠ verify sections

- **Search and seizure powers** flow from the **BNSS 2023** (which replaced the CrPC 1973) — search with/without warrant, seizure of property, and the requirement of **witnesses to the seizure** (the *panchnama*). ⚠ verify the exact BNSS section numbers before quoting (the CrPC analogues were §§91–105 for production/search and §165 for police search).
- **IT Act 2000 §80** — power of a police officer (not below a specified rank) to **enter and search a public place and arrest without warrant** for IT Act offences ⚠ verify rank/section.
- **IT Act §69 / §69A / §69B** — powers to **intercept/monitor/decrypt**, to **block**, and to **monitor and collect traffic data** — with the procedural safeguards/rules.
- **Admissibility of electronic evidence: §65B Indian Evidence Act 1872**, now **§63 Bharatiya Sakshya Adhiniyam 2023**, requires a **certificate** (the "§65B / §63(4) certificate") attesting how the electronic record was produced and that the computer was operating properly. ⚠ verify the exact BSA sub-section for the certificate. Cite both statutes in the exam.
- **BNSS forensic mandate:** forensic examination/collection is made mandatory for offences punishable with **7 years or more** — commonly cited as **BNSS §176(3)** ⚠ verify.

Golden rules to state: the seizure must be **lawful (authority + scope)**, **witnessed**, and **documented**, and the electronic record must ultimately be accompanied by the **§65B/§63 certificate** or it risks being inadmissible. Do not overstate a section number — write "⚠ verify" in your own notes and, in the exam, cite the concept plus both old/new statutes.

4.2 Search & seizure procedure for digital evidence (the drill)

1. **Plan** — know the target, the likely devices, encryption risk, and get the right authority.
2. **Secure the scene**, restrict access, and **document** the state on arrival.
3. **Photograph** the setup before touching anything.
4. **Assess power state** and apply the pull-plug/graceful/live logic (§3.4).
5. **Capture volatile evidence** (if ON and trained) in **order of volatility** (§4.3).
6. **Isolate from networks** (cable out / Faraday) to stop remote wipe and change.
7. **Label and seize** all storage and devices — including phones, USBs, SD cards, routers, NAS, cameras, notes/passwords, chargers, cables.
8. **Image on-site or seize for lab imaging** using **write blockers**; compute **hashes** at acquisition.
9. **Begin/continue the chain of custody**, seal exhibits, record seal numbers and hashes.
10. **Transport** safely (anti-static, cushioned, away from magnets/heat) to the lab.

4.3 Order of volatility — memorise the list (RFC 3227)

Principle: collect evidence **from the most volatile to the least volatile**, because the act of collecting the less-volatile items (or simply the passage of time) destroys the more-volatile ones.

Derived from **IETF RFC 3227**, "Guidelines for Evidence Collection and Archiving".

The canonical ordered list (most → least volatile):

#	Evidence	Lifetime	Note
1	CPU registers, cache	Nanoseconds–ms	Effectively uncapturable in practice
2	Routing table, ARP cache, process table, kernel stats, live network connections	Seconds	Capture with live IR tools before they change/age out
3	Main memory (RAM) — running processes, open files, clipboard, encryption keys , injected/fileless malware, decrypted data	Until power off	The prize; capture first among the "collectable" items
4	Temporary file systems (swap/pagefile, tmpfs, <code>/tmp</code>)	Minutes–reboot	May hold fragments of memory/decrypted data
5	Disk / non-volatile storage (the drive image)	Persistent	The main dead-box exhibit
6	Remote logging & monitoring data relevant to the system	Depends on retention	Firewall/IDS/SIEM, server logs — grab before rotation
7	Physical configuration & network topology	Static	Diagram, cabling, device inventory
8	Archival media (backups, tapes, optical)	Long-lived	Least volatile; collect last

How to reproduce fast in the exam: *Registers/cache → ARP & routing & process tables & network connections → RAM → swap/temp files → disk → remote/monitoring logs → physical topology → archival backups.* Attach the reasoning ("collect volatile first because collecting stable evidence or time itself destroys volatile evidence") and cite **RFC 3227**.

Link to TP-I: this is the **Law of Progressive Change** (FOR_01 §1.5) made operational — everything changes with time; the rate differs; so collect the fastest-changing first.

4.4 Live vs dead-box (static) forensics

Aspect	Live (online) acquisition	Dead-box (static/offline) acquisition
System state	Running	Powered off
Captures	RAM, running processes, network state, decrypted/mounted encrypted volumes, cloud sessions	Full bit-stream disk image
Integrity	Harder — the running OS changes state; a rootkit may lie about what is present	Cleaner — evidence is frozen; write-blocked imaging is repeatable
When forced	Encryption unlocked; RAM-only/fileless malware; can't power down (critical server); cloud/remote data	Machine already off; malware may hide from live OS; want maximum integrity
Risk	Every action alters some state (document + justify per ACPO P2)	Missing all volatile evidence

Modern reality: because full-disk encryption and fileless malware are now common, **live acquisition of RAM first, then dead-box imaging of the disk** is the standard combined approach — you no longer get to choose only one.

§4.5 Likely exam questions

Marks	Question
5	State the order of volatility of digital evidence.
5	What is the role of a first responder at a digital crime scene?
5	When would you pull the plug rather than shut down gracefully?
10	Describe the procedure for search and seizure of digital evidence.
10	Compare live and dead-box forensic acquisition. When is each appropriate?
15	A running, network-connected desktop with a suspected encrypted volume is found at a scene. Describe, with reasoning, how you would preserve and seize the digital evidence, referencing the order of volatility and Indian legal requirements.

MCQ traps

- Order of volatility comes from **RFC 3227**; **RAM before disk**, **registers/cache** are the most volatile.
- **ARP cache and routing table are volatile** (age out in minutes) — often mis-listed as stable.
- **Machine OFF → do not boot it.** Booting is not "just checking".
- **Unlocked encrypted volume → capture live before power-down**, or you may lose access permanently.
- §65B (IEA) / §63 (BSA) is about **admissibility via certificate**, not about seizure powers.

§5. Imaging and Hashing Digital Evidence

5.1 Bit-stream image vs logical copy — the fundamental distinction

	Bit-stream (physical) image	Logical copy
What it copies	Every sector of the device, byte-for-byte — allocated + unallocated + slack + HPA/DCO	Only the live files the file system reports
Recovers deleted data?	Yes (deleted files, slack, unallocated, carving all possible)	No — deleted/slack/unallocated are not copied
Size	Equal to the whole device	Equal to used data only
Use	The forensic default; the exhibit you analyse	When you legitimately need only specific files (e.g. huge server, or a targeted, authorised subset)
Verifiable by hash	Yes — hash the source and the image; they must match	Hash the individual files

Exam one-liner: *A forensic image is a bit-stream, sector-by-sector copy of the entire medium including unallocated space and slack; a logical copy grabs only visible files and therefore cannot recover deleted data. This distinction is asked constantly.*

Imaging vs cloning: an **image** is a *file* (raw/E01/AFF) representing the disk; a **clone** is a *disk-to-disk* copy onto another physical drive (bootable, but harder to hash/store as evidence). Prefer **imaging** for evidence; cloning for building a working test environment.

5.2 Write blockers

Concept: while acquiring, the examiner's machine must be able to **read** the evidence drive but **never write** to it — because a single write changes hashes and destroys integrity (and Windows *will* write to any disk it mounts: timestamps, *System Volume Information*, recycle bin).

Type	How it works	Note
Hardware write blocker	A physical device between the evidence drive and the workstation that intercepts and blocks all write commands at the interface (SATA/SAS/IDE/USB/NVMe/PCIe)	The gold standard ; interface-specific; also unlocks/reports HPA/DCO on good models
Software write blocker	OS/driver-level setting that blocks writes to the target (e.g. registry flag, forensic-boot mount as read-only)	Depends on the OS behaving; used with bootable forensic media; document the method

Verification: a defensible acquisition **records that a write blocker was in use** and proves integrity by hashing (§5.4). Best practice: hash the source **before** imaging (through the blocker), hash the resulting image, and confirm they match.

5.3 Image formats

Format	Full name / origin	Features
dd / raw	Output of the Unix <i>dd/dcfldd/dc3dd</i> tools	Pure bit-for-bit, no metadata, no compression; universally readable; hash stored separately
E01 (EWF)	EnCase Evidence File / Expert Witness Format	Compression, embedded case metadata (examiner, notes, dates), built-in CRC per block + stored hash → self-verifying ; can be split into segments (<i>.E01, .E02...</i>)
Ex01 / L01 / Lx01	Later EnCase variants; L01 is a logical evidence file (files, not full disk)	
AFF / AFF4	Advanced Forensic Format (open standard)	Open, extensible, compression, metadata, supports very large and cloud/remote images
AD1	AccessData custom logical image (FTK Imager)	Logical container with metadata
VMDK/ VHD/ VHDX	Virtual-disk formats	Sometimes used as targets; also <i>are</i> evidence in VM cases (§10)

MCQ trap: *dd/raw* carries **no metadata and no built-in hash** (store the hash yourself); **E01 embeds metadata and is self-verifying (CRC + stored hash)**. This contrast is a favourite.

5.4 Hashing — proving integrity

Concept: a **cryptographic hash** is a one-way function that maps any input to a fixed-length **digest**. Change one bit of the input and the digest changes completely (**avalanche effect**).

So the hash is the **digital fingerprint / digital seal** of the evidence: compute it at acquisition, and recompute later to prove **nothing changed**.

Algorithm	Digest size	Status
MD5	128-bit (32 hex chars)	Fast; collision-broken (deliberate collisions can be produced). Still widely used <i>for integrity verification of evidence</i> where you are checking against accidental change, but not to prove uniqueness against a determined adversary.
SHA-1	160-bit (40 hex chars)	Collision-broken (SHAttered, 2017). Being retired.
SHA-256	256-bit (64 hex chars)	Part of SHA-2 ; currently recommended ; no practical collisions.
SHA-512 / SHA-3	512-bit / sponge	Also strong; SHA-3 (Keccak) is a different construction.

The workflow (write this as steps):

1. With a **write blocker** attached, compute the hash of the **source** device.
2. Acquire the **bit-stream image**.
3. Compute the hash of the **image**; it must equal the source hash → the copy is **verified**.
4. Record both hashes in the chain-of-custody/notes; treat the hash as the **seal**.
5. Do all analysis on a **working copy**; before and after analysis, re-hash to prove the evidence copy is unchanged. Any mismatch must be **investigated and explained** (recall the SSD caveat — FOR_02 §2.2 — where garbage collection can legitimately change an SSD's hash between reads).

Collisions — what to say:

- A **collision** = two *different* inputs with the *same* hash. MD5 and SHA-1 have **practical, engineered collisions**; SHA-256 does not.
- **Why it does not automatically destroy MD5's evidentiary use:** producing a collision requires *crafting both files*; it does **not** let an adversary alter your seized evidence to match a given hash (that is a far harder **pre-image/second-pre-image** attack, still infeasible even for MD5). Best practice today: **compute two hashes (e.g. MD5 + SHA-256)** so a single broken algorithm cannot be argued to undermine integrity. Say exactly this if asked "is MD5 still acceptable?" — nuance scores.

Digital analogue of the seal (link to FOR_01): the hash is to a disk image what a tamper-proof seal + panchnama is to a physical exhibit — it proves the object produced in court is the object seized, unaltered.

§5.5 Likely exam questions

Marks	Question
5	Distinguish between a bit-stream image and a logical copy.
5	What is a write blocker and why is it essential?
5	What is a hash value? Name three hash algorithms with their digest sizes.
5	What is a hash collision? Is MD5 still usable for evidence?
10	Describe the process of forensically imaging and verifying a hard disk.
10	Compare raw (dd), E01 and AFF image formats.

15

Explain how the integrity of digital evidence is established and maintained from seizure to court, covering write blockers, imaging formats, hashing and the §65B/§63 certificate.

MCQ traps

- **MD5 = 128-bit; SHA-1 = 160-bit; SHA-256 = 256-bit.** Constantly swapped.
- **Logical copy cannot recover deleted files;** bit-stream can.
- **dd/raw has no embedded hash/metadata; E01 does.**
- A hash change means the data changed (unless a documented SSD-GC / drive-firmware reason applies).
- Write blocker blocks **writes to the evidence**, allowing reads.

§6. Recovery of Deleted, Hidden and Altered Files

6.1 Why deletion usually does not delete (the core idea)

On most file systems, "delete" only updates **bookkeeping** — the data blocks are marked free but the **bytes remain** until overwritten (recall FOR_02 §4: FAT sets the first name byte to **0xE5** and frees the chain; NTFS marks the MFT record unallocated; ext3/4 zero the block pointers). So there are three recovery regimes:

Regime	Method	Works when
Metadata-based recovery (undelete)	Read the still-present directory/MFT/inode entry to find the file's clusters	The metadata survives and the data is not overwritten (FAT contiguous files; NTFS resident/small; ext2)
File carving	Ignore the file system entirely; scan raw unallocated space for known file signatures and structure	Metadata is gone (formatted disk, zeroed pointers, corrupted FS) but the data bytes persist
Journal/log & shadow-copy recovery	Read \$LogFile/\$UsnJrnl (NTFS), the ext journal, or Volume Shadow Copies for old/deleted versions	Those structures still hold the relevant records/snapshots

6.2 File carving — the technique

Concept: carving reconstructs files **from content alone**, using **header (magic number)** and often **footer** signatures and internal structure, without any file-system metadata.

- **Header/footer carving:** find a known header (e.g. JPEG **FF D8 FF**) and the matching footer (JPEG **FF D9**), extract everything between. Works for contiguous files.
- **Fragment recovery / SmartCarving:** handles **fragmented** files by reassembling fragments — much harder; needs structure validation.
- **Limitations:** **fragmentation** defeats naive carving; a carved file has **no original name, path or timestamps** (those live in metadata); overwritten regions are unrecoverable; on **TRIM-enabled SSDs** the data is often already gone (FOR_02 §2.2). Tools: **PhotoRec/Scalpel/Foremost**, and the carving engines inside Autopsy/Encase/FTK.

6.3 File signature vs extension table — memorise this (guaranteed MCQ + practical answer)

Concept: the **extension** (.jpg, .pdf) is just part of the *name* and is **trivially changed** to hide a file; the **signature (magic number)** is bytes **inside** the file that reveal its **true type**. **File-signature analysis** = comparing the header bytes to the extension to detect **extension mismatch/masquerading** (e.g. a *secret.jpg* that is really a RAR archive, or an *.exe* renamed to *.txt*).

File type	Extension	Header (magic) bytes (hex)	ASCII / note	Footer (if any)
JPEG	.jpg/.jpeg	FF D8 FF (E0/E1/EE...)	ÿØÿ	FF D9
PNG	.png	89 50 4E 47 0D 0A 1A 0A	.PNG....	49 45 4E 44 AE 42 60 82 (IEND)
GIF	.gif	47 49 46 38 37 61 or 47 49 46 38 39 61	GIF87a / GIF89a	00 3B
PDF	.pdf	25 50 44 46	%PDF	25 25 45 4F 46 (%EOF)
ZIP / DOCX / XLSX / PPTX / JAR / APK / ODF	.zip etc.	50 4B 03 04 (also 50 4B 05 06 empty, 50 4B 07 08 spanned)	PK..	—
RAR	.rar	52 61 72 21 1A 07 00 (v4) / ...01 00 (v5)	Rar!..	—
7-Zip	.7z	37 7A BC AF 27 1C	7z¼~'.	—
GZIP	.gz	1F 8B	—	—
Windows PE (EXE/DLL)	.exe/.dll	4D 5A	MZ (Mark Zbikowski)	—
ELF (Linux exe)	—	7F 45 4C 46	.ELF	—
PDF-vs-Office note			modern Office = ZIP (PK); legacy Office (.doc/.xls/.ppt) = D0 CF 11 E0 A1 B1 1A E1 (OLE/CFBF)	
MP3	.mp3	49 44 33 (ID3 tag) or FF FB frame sync	—	—
MP4/MOV	.mp4	 66 74 79 70 (ftyp at offset 4)	—	—
PST/MS Outlook	.pst	21 42 44 4E (!BDN)	—	—
SQLite (many app DBs)	.db	53 51 4C 69 74 65 20 66 6F 72 6D 61 74 20 33 00	SQLite format 3	—

The five you must be able to write from memory: JPEG **FF D8 FF**, PDF **%PDF (25 50 44 46)**, PNG **89 50 4E 47**, ZIP/PK **50 4B 03 04**, EXE **MZ (4D 5A)**, plus GIF **GIF87a/ GIF89a**. These appear verbatim in MCQs and in the "how would you detect a file hiding its type" descriptive answer.

6.4 Hidden files and altered files

Hidden data — where it lurks:

- **Attributes/flags:** the Windows "Hidden"/"System" attribute; Linux **dot-files** (`.name`).
- **Alternate Data Streams (NTFS ADS)** — data hidden in a named stream on a file/folder (FOR_02 §5.7); invisible to normal listing; destroyed when copied to FAT/exFAT.
- **Slack space** (file slack, RAM slack) and **unallocated space** — leftover data from previous files (FOR_02 §5.9).
- **HPA/DCO** on HDDs; **over-provisioning** on SSDs (FOR_02 §2).
- **\$BadClus** abuse, partition gaps, boot-sector slack, inter-partition space.
- **Steganography** — data hidden *inside* other files (§6.5).
- **Renamed extensions / wrong magic** — caught by signature analysis (§6.3).

Altered files — detecting tampering:

- **Hash mismatch** against a known-good copy.
- **Timestamp anomalies** — `$SI` vs `$FN` MACE mismatch (**timestamping**, FOR_02); a "created" time later than "modified"; times inconsistent with `$LogFile/$UsnJrnl` or event logs.
- **Metadata/EXIF** inconsistencies (camera model, GPS, software field showing an editor).
- **Content vs container** mismatch (a PDF whose `%%EOF` is followed by appended data; an image with an embedded archive).

6.5 Steganography and steganalysis

	Steganography	Cryptography
Goal	Hide the existence of the message (security through concealment)	Hide the meaning (visible but unreadable)
Detectability	You should not even know a message is there	You know a ciphertext exists
Combined	Best practice: encrypt then hide	

Techniques: **LSB (Least Significant Bit)** substitution in image/audio pixels/samples (the classic); frequency-domain embedding (DCT coefficients in JPEG); text steganography (whitespace, word choice); **network steganography** (covert channels in packet fields); hiding files by **appending after a valid footer** (e.g. a ZIP concatenated after a JPEG — `copy /b img.jpg + secret.zip`); metadata fields.

Steganalysis (detection):

- **Signature/known-tool detection** — artifacts left by specific stego tools.
- **Statistical analysis** — LSB embedding disturbs the natural statistical distribution of pixel values (e.g. **chi-square**, **RS analysis**); anomalies flag hidden data.
- **File-size / structure anomalies** — a file larger than its visible content warrants; data after the footer; abnormal palette.
- **Comparison with a known-clean original** where available.
- **Extraction/brute-force** with candidate passwords once a tool is identified.

6.6 Anti-forensics — the adversary's toolkit (and the counter)

Technique	What it does	Examiner's counter
Secure wiping / overwriting	Overwrites data so it cannot be recovered	Look for wiping-tool artifacts, install/run records, remaining slack, shadow copies, backups

Encryption / full-disk encryption	Renders data unreadable without the key	Capture keys from RAM (live acquisition), password recovery, cloud/escrow keys, <code>hiberfil</code>
Steganography	Hides existence of data	Steganalysis (§6.5)
Timestamping	Alters MACE timestamps	<code>\$SI</code> vs <code>\$FN</code> mismatch; <code>\$LogFile/\$UsnJrnl</code> ; log correlation
Log tampering / clearing	Deletes/edits event logs	Recover from unallocated/shadow copies; remote SIEM copies; event ID 1102 (log cleared)
Data hiding	ADS, slack, HPA/DCO, bad-cluster abuse	Full bit-stream image + signature/slack/HPA analysis
Trail obfuscation / spoofing	Fake IPs, proxy/VPN/Tor, false artifacts	Corroborate across sources; ISP/legal process; timing analysis
Counter-tools / tool-detection	Detect and evade forensic tools; anti-VM/anti-debug malware	Use hardware acquisition; multiple independent tools
File-less / memory-only operation	Leaves little on disk	Memory forensics (Volatility)

§6.7 Likely exam questions

Marks	Question
5	What happens to a file's data when it is deleted? How is it recovered?
5	What is file carving? State its limitations.
5	Distinguish steganography from cryptography.
5	Write the header signatures of JPEG, PDF, PNG, ZIP and EXE.
5	What is timestamping and how is it detected?
10	Explain file-signature analysis and how it detects a file masquerading under a false extension.
10	Describe steganography techniques and the methods of steganalysis.
10	Discuss anti-forensic techniques and the examiner's countermeasures.
15	Discuss the recovery of deleted, hidden and altered files, covering undelete, carving, slack/unallocated space, ADS, steganography and the impact of SSD TRIM.

MCQ traps

- **JPEG = `FF D8 FF`; PDF = `%PDF`; PNG = `89 50 4E 47`; ZIP/Office = `PK(50 4B 03 04)`; EXE = `MZ`.**
- **Extension can be changed; the magic number reveals the true type** (signature analysis).
- **Carving ignores the file system**; recovered files lose name/timestamps.
- **Steganography hides existence; cryptography hides meaning.**
- **LSB** is the classic image steganography method.
- On a **TRIM SSD**, carving/undelete often **fails** because deleted data is zeroed autonomously.

§7. Browser Forensics

7.1 Concept

The browser is the **single richest record of user intent** on most machines — what the user searched, visited, downloaded, typed, logged into, and when. It answers "what was this person doing online, and did they *knowingly* seek the incriminating material?" (intent/knowledge is often the legal crux).

7.2 Artifacts and what each proves

Artifact	What it proves	Note
History (visited URLs + visit timestamps + visit count + transition type)	Sites visited, when, how often, and how they got there (typed vs link vs redirect)	Transition type distinguishes deliberate typing from a redirect/ad
Cache	The actual content (images/pages) the user saw, even if the site later changed or is offline	Proves what was <i>rendered</i> , with cache timestamps
Cookies	Sites visited, logged-in sessions, tracking, sometimes last-access; session vs persistent	Session cookies can prove an active login
Bookmarks / Favourites	Deliberate, durable interest in a site	Strong intent indicator
Downloads list	Files downloaded, source URL, target path, timestamps, size	Ties a file on disk to its origin
Autofill / saved form data & passwords	Names, addresses, emails, card hints, saved credentials	Attribution + intent
Typed URLs / search terms	What the user actively typed/searched	Highest-intent artifact
Session restore / tabs	Tabs open at last close / crash	Shows current activity
Extensions/plugins	Ad-blockers, VPNs, crypto wallets, malicious add-ons	Anti-forensic or capability indicators
Sync data	Activity across the user's <i>other</i> devices via the account	Expands scope beyond the seized device

7.3 Where the data lives (per browser)

Browser	Engine/store	Typical location
Chrome / Edge (Chromium) / Brave	SQLite databases	...\User Data\Default\ → History, Cookies, Web Data, Login Data, Bookmarks (JSON), Cache\ (Windows: %LocalAppData%\Google\Chrome\User Data\Default\)

Firefox	SQLite (places.sqlite = history+bookmarks; cookies.sqlite; formhistory.sqlite; logins.json)	%AppData%\Mozilla\Firefox\Profiles\<rnd>.default\
Internet Explorer (legacy)	WebCacheV*.dat (ESE/index.dat on older) + registry TypedURLs	%LocalAppData%\Microsoft\Windows\WebCache\
Legacy Edge	ESE WebCacheV01.dat	similar
Safari	plists + SQLite (History.db)	macOS ~/Library/Safari/

Practical tip for the answer: Chromium and Firefox store history in **SQLite** → an examiner can run SQL queries against the `History/places.sqlite` file (with a copy, read-only) to build a timeline; timestamps are in **WebKit/Chrome epoch (microseconds since 1601)** or **Unix epoch** — naming that conversion issue shows depth.

7.4 Private / Incognito mode — what survives (a favourite question)

Private mode is designed so the **browser does not persist** history/cookies/cache to that **profile's normal stores** after the window closes. But it is **not** anonymity, and traces remain elsewhere:

Survives / recoverable	Why
RAM while the session is open (and hiberfil/pagefile after)	Private data lives in memory → live memory capture recovers URLs, page content, even credentials
DNS cache (ipconfig /displaydns)	The OS still resolved the domains visited
Router/ISP/proxy/firewall logs	The network still saw the traffic
Downloaded files the user chose to keep	Downloads persist even if the download <i>list</i> does not
Temp files / crash dumps / pagefile / hiberfil	Fragments may be flushed to disk
OS artifacts — prefetch of the browser, jump lists, USN of temp files	Execution/activity traces
Server-side / account-side records	Websites and the user's synced account still logged the activity

Exam line: "Private browsing prevents local persistence in the browser's own stores; it does not prevent capture from RAM, DNS cache, network/ISP logs, downloaded files, or the remote server. Hence the correct response to a suspected private-mode session is live memory acquisition."

§7.5 Likely exam questions

Marks	Question
5	List the browser artifacts and state what each proves.
5	Where does Chrome/Firefox store history and in what format?

5	What survives a private/incognito browsing session?
10	Describe browser forensics and how it establishes user intent.
15	Explain how you would reconstruct a suspect's online activity from browser artifacts, including private-mode sessions.

MCQ traps

- **Chrome/Firefox history is stored in SQLite** (`History`, `places.sqlite`).
- **Private mode is not anonymous** — RAM, DNS cache, ISP logs, and downloaded files survive.
- **Cache stores the actual viewed content**; history stores URLs/timestamps.
- IE legacy used `index.dat` / `WebCacheV*.dat`.

§8. Email — Protocols, Architecture and Types

8.1 Concept

Email is the classic vehicle for phishing, BEC, threats, extortion, defamation and malware delivery, so **email forensics** is a core skill. The examiner asks: **Is this email genuine or spoofed? Where did it really originate? Who sent it?** The answer is written in the **headers** (§9). First, the plumbing.

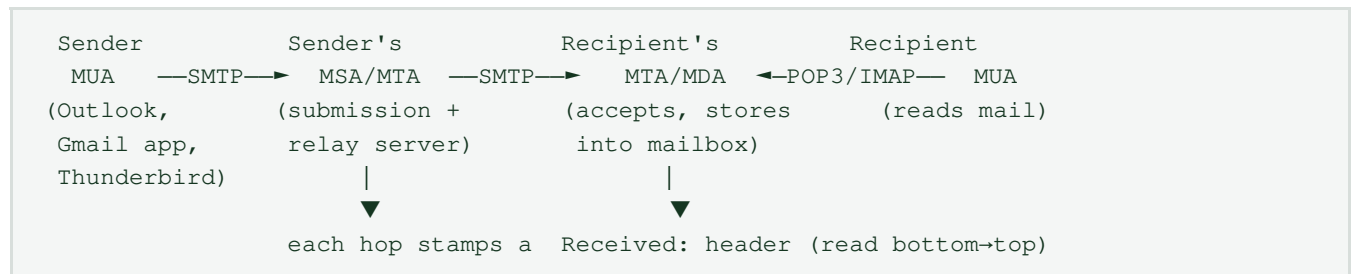
8.2 Protocols and ports

Protocol	Purpose	Default port(s)	Note
SMTP (Simple Mail Transfer Protocol)	Sending / relaying mail between servers (and client→server submission)	25 (server-to-server relay), 587 (client submission, STARTTLS), 465 (SMTPS/implicit TLS)	"Push" protocol; the one that writes <code>Received:</code> headers
POP3 (Post Office Protocol v3)	Client downloads mail from the server, typically deletes from server	110 (plain), 995 (POP3S/TLS)	Mail ends up on one device; poor for multi-device
IMAP (Internet Message Access Protocol)	Client syncs mail, mailbox stays on the server , folders synced across devices	143 (plain), 993 (IMAPS/TLS)	Modern default; server retains the authoritative copy
MIME (Multipurpose Internet Mail Extensions)	Not a transport — the standard that lets email carry attachments , non-ASCII text , multiple parts (<code>Content-Type</code> , <code>boundary</code> , Base64/quoted-printable encoding)	—	Attachments are Base64-encoded MIME parts
MAPI / Exchange, HTTPS webmail	Proprietary/enterprise and browser-based access	443 etc.	Gmail/Outlook web, Exchange

MCQ trap: SMTP sends; POP3 and IMAP receive. POP3 downloads-and-deletes (single device); IMAP keeps mail on the server (multi-device sync). MIME handles attachments, not

transport. Ports 25/587/465 (SMTP), 110/995 (POP3), 143/993 (IMAP) are examinable.

8.3 Email architecture — the delivery chain



Agent	Role
MUA — Mail User Agent	The client the human uses (Outlook, Thunderbird, Gmail web/app)
MSA — Mail Submission Agent	Accepts the outgoing message from the MUA (port 587)
MTA — Mail Transfer Agent	Relays mail server-to-server via SMTP (adds a Received: header at each hop)
MDA — Mail Delivery Agent	Places the message into the recipient's mailbox for POP3/IMAP pickup

Key idea for §9: every MTA the message passes through prepends a **Received: header.** So the header block is a **stack** — the **topmost** **Received:** is the **last/nearest** hop (the recipient's server); the **bottommost** **Received:** is the **first/originating** hop. **Read the headers from the bottom upward to trace the origin.**

§9. Email Header Analysis — the line-by-line trace (set-piece 10/15-mark answer)

This is the single most reliable "big" question in the browser/email unit. Learn the method as a procedure, then walk a sample header. In the exam, **reproduce a plausible header and annotate it** — examiners reward the annotated trace, not prose.

9.1 The method (state these steps first)

1. **View the full/original headers**, not the friendly view (Gmail "Show original"; Outlook "Properties → Internet headers"; **.eml/.msg** source).
2. **Read **Received:** headers bottom-to-top.** The **bottom-most** shows the **originating** host/IP; each line up is the next relay.
3. **Extract the originating IP** from the bottom **Received:** and **geolocate / WHOIS** it; check it against the claimed sender.
4. **Compare **From:** vs **Return-Path:** (envelope sender) vs the authenticated domain** — a mismatch is a spoofing red flag.
5. **Check authentication results: SPF, DKIM, DMARC** in **Authentication-Results:** / **Received-SPF:**.
6. **Inspect **Message-ID**** — its domain should match the sending server; forged mail often has a mismatched or malformed Message-ID.

7. Check **Reply-To** — phishers set **Reply-To** to an attacker address different from **From**.
8. Note **Date**, **X-Mailer/User-Agent**, **X-Originating-IP**, and any **X-** anomalies.
9. Correlate the originating IP with ISP/legal process to reach a subscriber (the attribution step), and preserve everything under §65B/§63 with hashes.

9.2 Anatomy of the important header fields

Field	Meaning	Forensic use
Received: (one per hop)	Added by each MTA: <code>from <claimed> (real-host [real-IP]) by <server> ... ; <date></code>	The trace backbone. Bottom = origin. The <code>(host [IP])</code> in parentheses is the receiving server's own observation — harder to forge than the "from" claim
From:	Displayed sender	Easily spoofed ; compare with authenticated domain
Return-Path: / envelope-from	Where bounces go (SMTP MAIL FROM)	Often reveals the true sending domain; mismatch with From: = suspicious
Reply-To:	Where replies go	Phishing points this at the attacker
Message-ID:	Unique ID <code><random@sending-domain></code>	Domain should match sender's server; forgeries mismatch
Authentication-Results:	Server's verdict on SPF/DKIM/DMARC	<code>spf=pass/fail, dkim=pass/fail, dmarc=pass/fail</code>
Received-SPF:	SPF check result	<code>fail</code> = sending IP not authorised for the domain
DKIM-Signature:	Cryptographic signature over selected headers+body	<code>dkim=pass</code> proves the body/headers were not altered and the domain signed it
X-Originating-IP:	Some webmail records the client IP	Can reveal the true composing client (not always present/trustworthy)
Date: , X-Mailer: / User-Agent:	Compose time and client software	Timeline; mismatched/absent mailer can indicate a script/bulk-sender

9.3 SPF, DKIM, DMARC (the anti-spoofing trio — define crisply)

Mechanism	What it checks	Passes when
SPF (Sender Policy Framework)	Is the sending server's IP authorised to send for the envelope domain? (DNS TXT record lists allowed IPs)	The connecting IP is in the domain's SPF record
DKIM (DomainKeys Identified Mail)	Was the message cryptographically signed by the domain and unaltered in transit? (public key in DNS)	The DKIM signature verifies against the domain's published key
DMARC (Domain-based Message Authentication, Reporting & Conformance)	Do SPF/DKIM align with the visible From: domain , and what policy to apply (<code>none/quarantine/reject</code>) if not?	Aligned SPF or DKIM pass; policy tells receivers what to do on failure

Spoof indicator summary: `spf=fail` and/or `dkim=fail` and/or `dmARC=fail`, plus a **From:** domain that differs from the authenticated/**Return-Path:** domain, plus an originating IP that does not belong to the claimed sender's network ⇒ spoofed / phishing.

9.4 Worked walkthrough (illustrative header — annotate one like this in the exam)

```
Delivered-To: victim@example.com
Received: by 2002:...:0 with SMTP id x; [4] recipient's
Google server (last hop)
    Tue, 12 Aug 2026 10:15:04 -0700 (PDT)
Received: from mail.trusted-bank.co (mail.trusted-bank.co [203.0.113.9]) [3] claims to be
the bank...
    by mx.google.com with ESMTPS id ...
    for <victim@example.com>; Tue, 12 Aug 2026 10:15:03 -0700 (PDT)
Received: from webmail.cheap-host.ru (webmail.cheap-host.ru [198.51.100.77]) [2] ...but
really relayed from a Russian host
    by mail.trusted-bank.co with ESMTP; Tue, 12 Aug 2026 20:15:01 +0300
Received: from [45.86.xx.xx] (unknown [45.86.xx.xx]) [1] ORIGIN: the
actual composing client IP (bottom)
    by webmail.cheap-host.ru with HTTP; Tue, 12 Aug 2026 20:14:59 +0300
Return-Path: <billing@cheap-host.ru> envelope sender ≠
From: → RED FLAG
From: "Trusted Bank Security" <security@trusted-bank.co> displayed sender
(spoofed)
Reply-To: <recover-account@secure-verify.info> replies go to
attacker → RED FLAG
Message-ID: <9f2c@cheap-host.ru> domain ≠ trusted-
bank.co → RED FLAG
Authentication-Results: mx.google.com;
    spf=fail (google.com: domain of billing@cheap-host.ru does not designate
45.86.xx.xx);
    dkim=none; dmarc=fail (p=REJECT) SPF fail + DKIM
none + DMARC fail → SPOOFED
Subject: Urgent: verify your account within 24 hours
Date: Tue, 12 Aug 2026 20:14:59 +0300
X-Mailer: (absent) no normal client
→ likely script/kit
```

Reading the trace (bottom → top): the message originated at `[45.86.xx.xx]` [1] composing on a webmail at `cheap-host.ru` [2], was relayed through a server *claiming* to be the bank [3], and delivered to the victim's Google server [4].

Verdict — spoofed phishing. Evidence: (a) **From:** = `trusted-bank.co` but the **origin IP** and **Return-Path/Message-ID** belong to `cheap-host.ru`; (b) `spf=fail`, `dkim=none`, `dmARC=fail` (`p=REJECT`); (c) **Reply-To** points to an unrelated attacker domain; (d) **urgency in the subject** and **missing X-Mailer**. **Next step:** WHOIS/geolocate `45.86.xx.xx` and `198.51.100.77`, issue legal process to those hosts/ISPs for subscriber data, preserve the `.eml` with a hash and §65B/§63 certificate.

How to score: write the header, number the **Received:** lines, mark the origin at the bottom, then list the four red flags (From vs Return-Path/Message-ID, SPF/DKIM/DMARC, Reply-To, origin

IP) and end with the ISP-subscriber attribution + §65B/§63 preservation step.

§9.5 Likely exam questions

Marks	Question
5	Distinguish SMTP, POP3 and IMAP with their ports.
5	What are SPF, DKIM and DMARC?
5	Draw and label the email architecture (MUA/MSA/MTA/MDA).
10	Explain email header analysis and how the originating IP is traced.
15	Given an email header, trace its origin and determine whether it is spoofed. Explain each indicator and the legal steps to attribute and preserve it.

MCQ traps

- **SMTP sends (25/587/465); POP3 receives (110/995); IMAP syncs (143/993); MIME = attachments.**
- **POP3 downloads-and-deletes; IMAP keeps mail on server.**
- **Read `Received:` headers bottom-to-top; bottom = origin.**
- **SPF = authorised IP; DKIM = signature/integrity; DMARC = alignment + policy.**
- **`From:` is easily spoofed; `Return-Path/Received/Message-ID` are harder to forge.**

§10. Virtual Machine and Cloud Forensics

10.1 Virtual machine forensics

Concept: a VM is a computer expressed as **files** on a host. That is a gift and a complication: the "disk" and even the "RAM" of the suspect machine may be sitting as ordinary files you can copy.

Artifact / file	Contents	Forensic value
Virtual disk — <code>.vmdk</code> (VMware), <code>.vhd/.vhdx</code> (Hyper-V), <code>.vdi</code> (VirtualBox), <code>.qcow2</code> (QEMU/KVM)	The VM's disk	Mount/image it like a physical disk — full file-system forensics apply
<code>.vmem</code> / saved-state / <code>.bin</code>	The VM's RAM when suspended/snapshotted	A ready-made memory image — run Volatility on it; often the best evidence
Snapshots (<code>.vmsn</code> , delta/differencing disks)	Point-in-time states	Recover earlier states / deleted data ; each snapshot is a timeline point
Config (<code>.vmx</code> , XML)	Hardware config, MACs, paths, timestamps	Ties the VM to a host and time
Logs (<code>vmware.log</code> etc.)	Power events, snapshot ops	Activity timeline

Points to make: (1) VMs enable **easy anti-forensics** (a VM can be deleted wholesale, or run

from a USB leaving little on the host) and **anti-analysis malware** (VM-aware malware alters behaviour); (2) **snapshots and the .vmem file are advantages** to the examiner — snapshots preserve history and .vmem gives free memory forensics; (3) **nested/host relationship** — always image the **host** too, and note that the host may hold the only copy of a deleted VM.

10.2 Cloud forensics — why it is hard

Concept: in the cloud the data is **somewhere else, owned operationally by a third party, spread across shared infrastructure, and constantly changing**. Traditional "seize the box" forensics does not apply — you cannot image a hyperscaler.

Challenge	Explanation
Loss of physical access / control	You cannot seize the hardware; you depend on the CSP and its APIs/logs
Multi-tenancy	One physical server holds many customers' data → isolation and privacy limits, risk of collateral exposure
Jurisdiction	Data (and its replicas) may sit in multiple countries → conflicting laws, MLAT , data-localisation issues
Elasticity / volatility	Instances spin up/down; storage is reallocated → evidence can vanish ; timelines are fragmented
Provenance & chain of custody	Harder to prove where data was and that it is unaltered when the CSP handled it
Dependence on the provider	Availability, completeness and format of logs are set by the CSP; you rely on their cooperation
Encryption & key management	Provider- or customer-managed keys control access
Shared responsibility	Security/evidence duties split between customer and provider per the service model

Service-model effect on what you can get:

Model	Customer controls (evidence you can reach)	Provider controls
IaaS	The VM/OS, disks, app data → most forensic access (snapshot the volume, image the instance)	Hypervisor, physical layer
PaaS	App and its data/logs	OS, runtime, infra
SaaS	Only application-level data/exports and audit logs → least direct access	Everything else

Approach: use **CSP-native tools** (volume/instance **snapshots, audit/activity logs** — e.g. access logs, IAM/CloudTrail-style records), **legal process to the provider**, preserve with hashes, and document the **shared-responsibility** boundary and jurisdiction. **SLAs and contracts** should pre-provide for forensic access and log retention. Standards: **NIST guidance on cloud forensic challenges** ⚠ verify document number before quoting.

§10.3 Likely exam questions

Marks	Question
5	What files make up a virtual machine and what is each worth forensically?
5	Why is the <code>.vmem</code> /snapshot valuable to an examiner?
5	State three challenges of cloud forensics.
10	Describe virtual machine forensics and its advantages and pitfalls.
10	Discuss the challenges of cloud forensics (multi-tenancy, jurisdiction, volatility, chain of custody).
15	Compare traditional disk forensics with VM and cloud forensics, explaining how acquisition and chain of custody change in each.

MCQ traps

- `.vmem` = VM memory image; `.vmdk/.vhd/.vdi/.qcow2` = virtual disks; `.vmsn` = snapshot.
- Snapshots preserve earlier/deleted states — an advantage, not just a complication.
- Multi-tenancy and jurisdiction are the defining cloud-forensic problems.
- IaaS gives the most forensic access; SaaS the least.

Appendix — verify-before-exam list for FOR_03

1. IT Act 2000 section numbers used: **§43, §43A, §65, §66, §66C, §66D, §66E, §66F, §67/§67A/§67B, §69/§69A/§69B, §70/§70A/§70B, §72/§72A, §79, §80** — confirm each against the bare act; do not invent others.
2. **BNSS** search/seizure section numbers (CrPC analogues were §§91–105, §165) and the **7-year forensic mandate** (commonly cited **BNSS §176(3)**) — △ verify.
3. **§65B Indian Evidence Act 1872** → **§63 BSA 2023** certificate sub-section — △ verify (cite both).
4. **DPDP Act 2023** operative status, terminology and any section numbers — awareness only; △ verify.
5. *K.S. Puttaswamy (2017)* privacy citation spelling — △ verify before quoting.
6. **IT Rules 2021** intermediary/first-originator status (subject to litigation) — △ verify.
7. USB/device **event IDs** and any GUIDs quoted from FOR_02 cross-refs — △ verify.
8. RFC number for order of volatility = **RFC 3227** (safe to cite).
9. NIST cloud-forensics document number — △ verify before quoting a number.